

PicoCTF 2026 – Fool The Lockout

Fool the Lockout

Web Exploitation Medium 200 pts 1,928 solves

by David Gaviria

Your friend is building a simple website with a login page.
To stop brute forcing and credential stuffing, they've added an IP-based rate limit: exceed the attempt threshold and your IP is blocked for a while. They're convinced this makes guessing credentials impossible.
To test their defense, they've:
Created a dummy account with a random username–password pair from public credential lists.
Given you those username and password lists.
Shared the full source code.
Can you bypass the rate limit, log in, and capture the flag?

In this challenge, we're told to bypass the brute-force defenses on this web app and perform a brute force / credential stuffing attack

PicoCTF 2026 – Fool The Lockout

Credential Stuffing



Credential stuffing is a web app attack where pairs of credentials (username and password) are systematically sent to a web app login page in an attempt to discover valid credentials

PicoCTF 2026 – Fool The Lockout Brute Force Protections



We've been told that this app has an IP-based rate limiting system, which could lockout requests from our IP address and prevent a credential stuffing attack

PicoCTF 2026 – Fool The Lockout

Inspecting the App Code

```
MAX_REQUESTS = 10  
EPOCH_DURATION = 30
```

We are given the source code for the app, and if we look at the way the IP lockout mechanism works, we see that there is a potential bypass

PicoCTF 2026 – Fool The Lockout

Inspecting the App Code

```
MAX_REQUESTS = 10  
EPOCH_DURATION = 30
```

The code states that the maximum number of requests a user can make before their IP is locked out is 10, and that the number of requests is reset after 30 seconds

PicoCTF 2026 – Fool The Lockout Rate-Limiting Bypass

```
MAX_REQUESTS = 10  
EPOCH_DURATION = 30
```

This means that we could send 9 requests in a brute force attack, then wait 30 seconds for the request counter to reset, then send another 9 requests, then wait another 30 seconds, etc, etc..

PicoCTF 2026 – Fool The Lockout Rate-Limiting Bypass



In this way, we can perform our credential stuffing attack in batches of 9 requests, waiting a little more than 30 seconds between each batch

PicoCTF 2026 – Fool The Lockout Rate-Limiting Bypass

```
with requests.Session() as s:
    r = s.post(
        f'{host}/login',
        data={'username': user, 'password': pw},
    )
    if "Invalid" not in r.text:
        print(f'\n[SUCCESS] {user}:{pw}')
        print(f'[RESPONSE] {r.text}')
        sys.exit(0)
```

We'll be using a Python script to perform the credential stuffing attack, since it can keep track of the credential pairs, the batches of requests, and the waiting period between batches